UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

6-3-2026

CNO V: Seguridad Informática

Hernández Fernández Diego Osvaldo

182217

Mtro. Servando López Contreras}

PR02

Investigación comparativa de plataformas

Contenido

Marco teórico y fundamentación técnica 2
Hoxhunt 2
Proofpoint 3
KnowBe4 3
Cofense 4
Phished 4
NINJIO 5
Mimecast 6
Infosec IQ 6
Tabla Comparativa 7
Análisis crítico y conclusiones 0
Referencias 1

Marco teórico y fundamentación técnica

La gestión del riesgo humano (HRM) en ciberseguridad parte de una premisa consolidada: el factor humano sigue siendo el vector de ataque más explotado, con la mayoría de incidentes originados en errores de usuario mediante phishing, ingeniería social o robo de credenciales. Frente a esto, las plataformas de concientización evolucionaron desde cursos de cumplimiento normativo hacia arquitecturas integradas que combinan simulación de amenazas, análisis conductual y respuesta a incidentes.

Estas plataformas se apoyan en tres pilares teóricos. El primero es la psicología del comportamiento: la evidencia en ciencias del aprendizaje demuestra que las personas retienen mejor los conocimientos a través de entrenamientos frecuentes, cortos y contextualizados, en lugar de módulos anuales extensos que se olvidan con rapidez. El segundo es la inteligencia de amenazas: la efectividad de una simulación depende de su fidelidad técnica respecto a ataques reales, por lo que las plataformas que ingieren indicadores de compromiso (IoC) activos producen escenarios más representativos que las que operan con plantillas estáticas. El tercero es la medición basada en resiliencia: la industria ha migrado de métricas de vanidad como la tasa de clics hacia indicadores de detección y reporte activo, reconociendo que un click rate bajo no siempre refleja una cultura de seguridad sólida.

En este contexto, el presente trabajo analiza comparativamente ocho plataformas líderes: Hoxhunt, Proofpoint PSAT, KnowBe4, Cofense, Phished, NINJIO, Mimecast e Infosec IQ, evaluando cuatro dimensiones clave en cada una: capacidades técnicas diferenciadoras, métricas y analítica de datos, metodologías de entrenamiento, y controles éticos en la gestión del factor humano.

Hoxhunt

Hoxhunt es una plataforma de Gestión del Riesgo Humano (HRM) que combina inteligencia artificial con simulaciones de amenazas reales para transformar al personal en una extensión operativa del SOC, en lugar de tratarlo como el eslabón débil de la cadena de seguridad.

A diferencia de las soluciones tradicionales basadas en plantillas estáticas, Hoxhunt genera campañas dinámicas mediante un motor de IA que analiza inteligencia de amenazas globales y el contexto del usuario, integrado con Google Workspace o Microsoft 365 para determinar de forma autónoma el vector de ataque, el pretexto y el momento óptimo de entrega. Su módulo Hoxhunt Respond automatiza la respuesta a incidentes: cuando un usuario reporta un correo sospechoso, el sistema analiza cabeceras, metadatos y enlaces, clasifica la amenaza y puede eliminar mensajes similares en toda la organización, reduciendo la carga manual del equipo de seguridad.

En cuanto a métricas, la plataforma prioriza la Tasa de Reporte sobre la tasa de clics, considerada una métrica de vanidad en aislamiento, complementándola con un Risk Score por usuario y departamento, y el Dwell Time, que mide el tiempo entre la llegada de una amenaza y su reporte.

Su metodología se basa en micro-entrenamientos just-in-time de 1-2 minutos activados tras cada fallo, simulaciones adaptativas de hasta 36 envíos anuales y gamificación para consolidar

hábitos. Todo esto bajo un marco ético que prohíbe la penalización por errores y restringe el uso de señuelos emocionalmente manipuladores.

También algo importante a destacar es que se caracteriza por mantener la información en privado ya que solo a los líderes se les permite visualizar áreas de vulnerabilidad (por ejemplo, detectar que el departamento de finanzas tiene un alto riesgo de spearphishing) sin exponer a individuos de todos los departamentos, evitando prácticamente el chisme.

Proofpoint

Proofpoint PSAT es una plataforma de Gestión del Riesgo Humano cuya principal ventaja competitiva reside en su integración nativa con el ecosistema de seguridad perimetral de Proofpoint, lo que le permite operar con visibilidad real sobre el panorama de amenazas activo de la organización.

Su diferenciador técnico más relevante es la sincronización con TAP (Targeted Attack Protection), que ingiere IoCs en tiempo real para lanzar Threat-Driven Campaigns: simulaciones que replican ataques de phishing activos antes de que impacten masivamente a la organización. Esto se complementa con el modelo VAP (Very Attacked People), un algoritmo que identifica a los usuarios más expuestos y les asigna automáticamente simulaciones más exigentes y controles técnicos adicionales, como el aislamiento de navegación. Para el cierre del ciclo operativo, la tecnología CLEAR analiza en sandbox cada correo reportado vía PhishAlarm y, si se confirma malicioso, purga instancias idénticas en todos los buzones corporativos en minutos.

En métricas, la plataforma cruza la Puntuación de Vulnerabilidad que combina resultados de capacitación, historial de simulaciones y clics en ataques reales con el Índice de Ataque (escala 0-1000), generando un mapa de calor que identifica qué usuarios concentran mayor riesgo operativo real.

Su metodología de entrenamiento sigue el ciclo ACE (Assess, Change, Evaluate) y asigna micro-módulos específicos según el tipo de amenaza que enfrenta cada usuario, con retroalimentación inmediata y personalizable por el administrador.

Éticamente, la plataforma recomienda que la clasificación VAP se use para aplicar controles compensatorios, nunca para estigmatizar, y sugiere validar campañas sensibles con RRHH o Legal antes de su despliegue.

KnowBe4

KnowBe4 se posiciona como la plataforma de concientización y simulación de phishing más grande del mercado, construida sobre la metodología de ingeniería social de Kevin Mitnick y orientada a replicar las tácticas reales que utilizan los atacantes.

Su arquitectura se apoya en tres componentes técnicos centrales. PhishER funciona como una plataforma SOAR ligera: categoriza automáticamente los correos reportados mediante reglas YARA y ML, y ejecuta PhishRIP para eliminarlos de todos los buzones corporativos. AIDA va un paso más allá al simular conversaciones de phishing en cadena, probando si el usuario revelaría información confidencial bajo un pretexto sostenido. Por su parte, los Smart Groups sincronizan con Active Directory para mover usuarios entre grupos de forma dinámica inscribiéndolos en remediación o restringiendo accesos en función de su comportamiento en simulaciones.

En métricas, su indicador ancla es el Phish-Prone Percentage (PPP), que establece una línea base de susceptibilidad y mide su reducción a los 90 días y al año. Esto se complementa con el Virtual Risk Officer (VRO), que genera un Personal Risk Score de 0 a 100 incorporando variables como exposición de credenciales en Dark Web, cargo y nivel de acceso. Para medir madurez cultural, aplica el Security Culture Survey, un instrumento validado científicamente que evalúa siete dimensiones del comportamiento humano.

Su biblioteca de contenido supera los 10,000 recursos en más de 34 idiomas, con adaptación cultural real, no traducción literal y producción de alta calidad orientada a reducir la fricción de consumo.

En materia ética, tras la polémica pública por simulaciones con pretextos de bonos navideños, la plataforma incorporó un sistema de calificación de plantillas por sensibilidad (1-5 estrellas) y advertencias explícitas en consola, manteniendo el control de aprobación en manos del administrador, sin delegarlo a la IA.

Cofense

Cofense parte de una premisa operativa clara: las tecnologías perimetrales eventualmente fallan, por lo que la última línea de defensa es el factor humano. Toda su arquitectura está diseñada para convertir al empleado en un sensor activo de amenazas.

Su diferenciador técnico más sólido es la suite Triage + Vision: mientras PhishMe ejecuta las simulaciones, Cofense Triage ingiere los reportes reales y simulados, los agrupa por campaña mediante reglas YARA y automatización, y Vision elimina los correos maliciosos en toda la red corporativa en tiempo real. A esto se suma el Phishing Defense Center (PDC), una red global de analistas que procesa millones de correos reportados para convertir IoCs de ataques activos en plantillas de simulación, garantizando que los escenarios sean técnicamente equivalentes a las amenazas del momento. Su complemento Cofense Reporter captura cabeceras completas y metadatos forenses sin alterar la evidencia, empaquetándola directamente para el SOC.

En métricas, la plataforma rechaza el Click Rate como indicador aislado y centra su modelo en el Resiliency Ratio: la división entre Reporting Rate y Susceptibility Rate. Un ratio de 3.0 donde tres usuarios reportan por cada uno que falla indica que el SOC recibirá alertas mucho antes de que ocurra una brecha. Esto se complementa con el Time-to-Report, que mide en minutos la velocidad de reacción humana ante una campaña.

Su entrenamiento prescinde de módulos largos y aplica Teachable Moments inmediatos: retroalimentación en menos de 5 segundos tras cada fallo, con playbooks adaptados por rol y nivel de exposición real al riesgo.

Éticamente, prohíben el naming and shaming y someten sus plantillas basadas en amenazas reales a revisión humana por parte del PDC para filtrar escenarios de impacto emocional severo, coordinando cualquier campaña sensible con RRHH y Legal.

Phished

Phished es una plataforma de concienciación en ciberseguridad nativamente impulsada por IA, cuya propuesta central es operar en modo **Zero-Touch**: sin intervención administrativa, sin campañas programadas manualmente y sin carga operativa para el equipo de TI.

Su motor de simulación rastrea la huella digital pública de la organización, analiza el comportamiento individual de cada usuario y lanza simulaciones continuas y aleatorias de phishing y smishing de forma autónoma. Dentro del cliente de correo, el **Phished Assistant** actúa como un agente residente que analiza correos en tiempo real bajo demanda del usuario, reduciendo el volumen de tickets a la mesa de ayuda. Su capacidad más diferenciada es **Zero Incident Mail (ZIM)**, que opera bajo un modelo Zero-Trust y es capaz de contener un ataque genuino incluso si el empleado ya hizo clic, antes de que el payload afecte la red.

Su métrica principal es el **Behavioral Risk Score (BRS)**, un indicador dinámico que ajusta la puntuación de riesgo individual en tiempo real según simulaciones fallidas, módulos completados y reportes activos. Complementa esto con una segmentación automática de la tasa de clics que distingue entre errores aislados y reincidentes, aumentando la frecuencia de simulaciones para estos últimos hasta corregir el hábito.

En entrenamiento, la **Phished Academy** genera rutas de aprendizaje adaptativas por perfil y área de fallo, con microcontenido activado inmediatamente tras cada error. Su localización es nativa no traducida, adaptando señuelos a marcas, instituciones y modismos del país de cada usuario.

Éticamente, opera bajo **Privacy by Design** con cumplimiento estricto del GDPR, aplicando minimización de datos y anonimización de reportes. Al delegar la lógica de campañas al algoritmo, elimina el sesgo del administrador, y programa límites automáticos de frecuencia si detecta fatiga de simulaciones en el usuario.

NINJIO

NINJIO fundamenta su arquitectura en la teoría del transporte narrativo: en lugar de módulos corporativos convencionales, entrega episodios animados de 3-4 minutos basados en brechas reales, desarrollados por guionistas con experiencia en producción televisiva. El supuesto central es que la retención narrativa reduce directamente la vulnerabilidad técnica.

Su motor de simulación, NINJIO PHISH3D, se sincroniza algorítmicamente con este contenido: si un usuario falla una simulación de BEC, el sistema inyecta automáticamente el episodio que documenta una brecha real equivalente. Ante eventos de alto impacto global vulnerabilidades zero-day, ransomware masivo, su capacidad de Agile Threat Intelligence permite producir y desplegar simulaciones y micro-entrenamientos asociados en días, no semanas. Complementa esto NINJIO Sense, un motor de ciencias del comportamiento que mide el compromiso cognitivo real: tiempo de visualización, pausas e interacción con cuestionarios, integrando todo en el perfil de riesgo del usuario.

En métricas, el NINJIO Risk Algorithm pondera tres variables: Click Rate (vulnerabilidad), Reporting Rate (defensa activa) y Engagement Rate (consumo proactivo vs. reactivo del contenido), diferenciando usuarios negligentes de aquellos simplemente sin formación suficiente. Añade la curva de olvido al análisis de susceptibilidad, midiendo cuánto tiempo transcurre entre el entrenamiento y la primera recaída.

Su entrenamiento opera bajo un modelo de temporadas mensuales con personajes recurrentes y gamificación por departamentos, sustituyendo el módulo anual por un ciclo continuo de bajo peso cognitivo.

Éticamente, el uso de personajes ficticios protege psicológicamente al empleado el error lo comete un tercero, no él, y su filosofía Catch and Release trata las simulaciones como diagnóstico, no como disciplina, limitando la remediación a un máximo de cinco minutos.

Mimecast

Mimecast es una plataforma de gestión del riesgo humano cuya ventaja competitiva estructural proviene de su posición como Secure Email Gateway (SEG) para miles de organizaciones, lo que le permite cruzar resultados de entrenamiento con telemetría de amenazas reales en tiempo real.

Su integración con Targeted Threat Protection (TTP) permite desplegar simulaciones y entrenamientos directamente a partir de ataques activos detectados por el SEG, sin necesidad de configuración manual adicional. Complementa esto con la capacidad de de-weaponization: tomar correos maliciosos bloqueados realmente, desactivar su payload y convertirlos en plantillas de simulación en minutos. Por su parte, Cybergraph utiliza ML para construir grafos de identidad y relaciones de comunicación, inyectando banners de advertencia dinámicos y ajustando el perfil de riesgo del usuario en consecuencia.

Su métrica central es el SAFE Score (escala 1-5), que cruza resultados de simulaciones con comportamiento real en red: intentos de apertura de enlaces bloqueados, reportes de amenazas genuinas y nivel técnico del usuario. Esto se complementa con Industry Benchmarking, que permite comparar Click Rate, Reporting Rate y SAFE Score contra organizaciones anónimas del mismo sector, ofreciendo al CISO un referente de mercado real.

En entrenamiento, su diferenciador es el uso deliberado del humor: miniseries estilo sitcom de 2-3 minutos con personajes recurrentes particularmente "Human Error" diseñadas para eliminar la resistencia cognitiva típica de la capacitación corporativa. La frecuencia e intensidad de los módulos se ajusta automáticamente según el SAFE Score individual.

Éticamente, la transparencia del SAFE Score es accesible al propio usuario, lo que convierte la mejora en un proceso autodirigido. Mimecast orienta explícitamente el uso de datos hacia remediación técnica como aislamiento de navegador para usuarios de alto riesgo desaconsejando su uso para decisiones disciplinarias o laborales.

Infosec IQ

Infosec IQ se diferencia del resto por su orientación prioritaria al cumplimiento normativo. Su arquitectura permite mapear cada módulo de entrenamiento directamente contra controles de marcos como NIST o ISO 27001, convirtiendo los resultados de capacitación en evidencia auditable.

Su motor se divide en dos componentes que operan en conjunto. PhishSim ofrece un constructor técnico drag-and-drop que permite clonar ataques reales, manipular cabeceras, inyectar variables de entorno y ajustar la dificultad de evasión de filtros sin depender de una IA de caja negra. AwareEd va más allá de sincronizar usuarios: mediante mapeo dinámico de atributos en Azure AD u Okta, detecta cambios de rol en el sistema de RRHH y reasigna automáticamente la currícula correspondiente por ejemplo, migrando a un usuario a codificación segura OWASP al asumir un puesto de desarrollo. Su complemento PhishNotify se integra vía webhooks y APIs RESTful con plataformas SOAR, permitiendo que un reporte de usuario detone playbooks de contención directamente en el SOC.

En métricas, sus dashboards están diseñados para sobrevivir auditorías: cruzan la relación clics/reportes por área y nivel técnico, registran el rendimiento individual en módulos como evidencia de cumplimiento, y traducen actitudes hacia las políticas internas en una puntuación de cultura cuantificable.

Su entrenamiento es estrictamente basado en roles: RRHH recibe formación en PII, personal médico en HIPAA y desarrolladores en OWASP. Incluye kits anuales preconfigurados con metodologías de narrativa interactiva tipo choose-your-own-adventure, y todos los módulos cumplen con estándares ADA/WCAG, un requisito crítico para entidades gubernamentales.

Éticamente, sus encuestas de cultura operan en modo anónimo para obtener respuestas honestas, y su marco desaconseja el engaño sistemático prolongado, enmarcando las simulaciones como herramientas de medición colectiva no de vigilancia individual.

Tabla Comparativa

Plataforma	Diferenciador Técnico	Métricas Principales (KPIs)	Enfoque de Entrenamiento	Control Ético y Gestión Humana
Hoxhunt	Cuenta con un motor de IA adaptativa (*Agentic AI*) que se integra nativamente con la respuesta a incidentes del SOC para lograr una purga automática de amenazas.	Se centra en la Tasa de Reporte y el Tiempo de Permanencia (*Dwell Time*), consolidando los datos en una Puntuación de Resiliencia.	Utiliza un microaprendizaje "*Just-in-Time*" de dificultad adaptativa, apoyado en una gamificación continua.	Fomenta una cultura libre de culpa, prohíbe los señuelos de "realismo cruel" y garantiza la total privacidad de los resultados.
Proofpoint	Destaca por su integración nativa con el filtro de correo (SEG) y la ingesta directa de telemetría de amenazas del mundo real mediante TAP.	Evalúa el *Accuracy Rate* y el *Vulnerability Score*, complementando el panorama con su Índice de Ataque (*Attack Index*).	Se basa en la metodología ACE, ofreciendo un entrenamiento dirigido específicamente por amenazas reales e inteligencia.	Protege a las personas muy atacadas (VAPs) para evitar su estigmatización y aplica regulaciones estrictas para medir el estrés.
KnowBe4	Incorpora una plataforma SOAR ligera e integrada (PhishER), apoyada por un agente conversacional de IA (AIDA) y la gestión dinámica mediante Grupos Inteligentes.	Su métrica ancla es el Porcentaje de Propensión (PPP), el cual cruza con el *Personal Risk Score* (PRS) y la Madurez de Cultura.	Ofrece una biblioteca masiva estilo "Netflix" con series de entretenimiento, manteniendo a los usuarios alerta con pruebas continuas.	Mantiene el control final en manos del administrador, fomentando esquemas de recompensas y refuerzo positivo.
Cofense	Se apoya en la inteligencia colaborativa (*Crowdsourced Threat Intel*) y un ecosistema Triage/Vision diseñado para facilitar el trabajo del SOC.	Su enfoque principal es la Tasa de Reporte, la cual se contrasta con la susceptibilidad para generar un Ratio de Resiliencia.	Aplica el condicionamiento operante brindando feedback en menos de 5 segundos, adaptando los escenarios mediante *playbooks* por roles.	Trata al humano como un sensor defensor, donde los analistas se encargan de sanitizar los señuelos sensibles para proteger al empleado.
Phished	Funciona con una automatización algorítmica al 100% (*Zero-Touch AI*), integrando un asistente que actúa como *coach* 24/7 en un entorno *Zero-Trust* (ZIM).	Mide el *Behavioral Risk Score* (BRS) y analiza detalladamente la Tasa de Interacción específica, prestando especial atención a los reincidentes.	Diseña rutas de aprendizaje generadas por inteligencia artificial, destacando por su profunda adaptación cultural y regional nativa.	Opera bajo un cumplimiento GDPR estricto, eliminando el sesgo del administrador y previniendo activamente la fatiga del usuario.
NINJIO	Utiliza una sincronización algorítmica llamada PHISH3D, impulsada por una inteligencia de amenazas ágil capaz de responder frente a brechas globales emergentes.	Implementa el *NINJIO Risk Algorithm*, el cual contrasta de manera directa la Tasa de Susceptibilidad con la curva de olvido del empleado.	Su núcleo es el *storytelling* de Hollywood, impartiendo microaprendizaje animado con un formato muy atractivo estilo cómic o anime.	Reduce la ansiedad mediante el aprendizaje en tercera persona, aplicando una filosofía de "capturar y liberar" sin ningún tipo de castigo.
Mimecast	Su mayor ventaja es la integración profunda con su propio perímetro SEG y el análisis avanzado de relaciones mediante gráficos de identidad (Cybergraph).	Emplea el *SAFE Score* de naturaleza predictiva, permitiendo además realizar un *Benchmarking* comparativo frente a otras empresas de la industria.	Emplea la comedia corporativa y las series cortas para reducir la fricción, logrando así retener la atención del colaborador.	Utiliza el humor como herramienta para reducir los niveles de cortisol, manteniendo una transparencia total de las puntuaciones con el usuario.
Infosec IQ	Permite un mapeo directo con normativas como NIST o GDPR, utilizando un constructor técnico muy granular (PhishSim) y una asignación dinámica (AwareEd).	Evalúa el *Learner Grade* para facilitar las auditorías de cumplimiento normativo, sumado a una Puntuación de Cultura de Ciberseguridad.	Imparte educación basada estrictamente en el rol de cada empleado, prestando especial atención a la accesibilidad inclusiva de su plataforma.	Ejecuta mediciones anónimas del clima laboral de TI y previene el uso del término "eslabón más débil" para evitar culpar al usuario.

Análisis crítico y conclusiones

El análisis comparativo de las ocho plataformas revela que no existe una solución universalmente superior; la elección óptima depende del perfil operativo, la madurez de seguridad y los requisitos regulatorios de cada organización.

Proofpoint y Mimecast presentan la ventaja más sólida en integración con infraestructura existente al operar como extensiones nativas de sus propios Secure Email Gateways, logrando una sincronización con amenazas reales que la mayoría de competidores no puede replicar sin integraciones de terceros. Cofense compensa esta limitación con su red global de analistas (PDC), ideal para organizaciones que priorizan la precisión forense. En automatización, Hoxhunt y Phished lideran al delegar las decisiones de campaña a motores de IA autónomos, diferenciándose en que Hoxhunt prioriza la integración con el SOC mientras Phished destaca por su cumplimiento GDPR y su contención activa mediante Zero Incident Mail.

KnowBe4 sigue siendo la referencia en escala y diversidad de contenido, con más de 10,000 recursos en 34 idiomas y gestión dinámica de usuarios mediante Smart Groups, aunque su modelo de control manual puede representar una carga administrativa elevada. NINJIO y Mimecast apuestan por el entretenimiento como vector de retención cognitiva, siendo menos adecuadas para auditorías de cumplimiento estricto, terreno donde Infosec IQ destaca por su mapeo directo con marcos como NIST o ISO 27001.

En conclusión, la selección debe responder a criterios concretos: infraestructuras Proofpoint o Mimecast se benefician de sus soluciones nativas; equipos pequeños o distribuidos, de Hoxhunt o Phished; entidades reguladas, de Infosec IQ; y organizaciones centradas en cultura, de NINJIO o Mimecast. En todos los casos, el éxito depende menos de la herramienta que de la coherencia con la política interna y el compromiso de la dirección con una cultura libre de culpa.

Referencias

Cofense. (s.f.). *Phishing defense powered by AI & human insight*. https://cofense.com/

Hoxhunt. (s.f.). *Human risk management platform*. https://www.hoxhunt.com/

Infosec Institute. (s.f.). *Infosec IQ security awareness training*. https://www.infosecinstitute.com/iq/

KnowBe4. (s.f.). *Security awareness training*. https://www.knowbe4.com/

Mimecast. (s.f.). *Security awareness training*. https://www.mimecast.com/products/security-awareness-training/

NINJIO. (s.f.). *Cybersecurity awareness training*. https://ninjio.com/

Phished. (s.f.). *AI-driven security awareness training*. https://phished.io/

Proofpoint. (s.f.). *Security awareness training*. https://www.proofpoint.com/us/products/security-awareness-training